



ASTRAQUANTUM TECH

SUMMER OF CYBERSECURITY 2026

WEEK 6 — PRACTICAL ASSIGNMENT

Cloud Security — Hands-on Learning & Security Assessment

IAM • Storage Security • Cloud Risks • Identity Management

Student Name: Mariam Fatima

Student ID: AQT-1372

Lab Platform: Pwned Labs

Date: 2 October 2026

1. Executive Summary

This report presents the practical work completed for the Cloud Security assessment. The assessment focused on identifying cloud security weaknesses involving **AWS Identity and Access Management (IAM)** and **Amazon S3**.

Two free cloud-security labs from Pwned Labs were completed:

1. **Intro to AWS IAM Enumeration**
2. **AWS S3 Enumeration Basics**

The first lab focused on IAM enumeration and understanding how IAM permissions can provide access to specific S3 resources. The second lab focused on S3 enumeration, publicly accessible cloud resources, exposed migration files, and insecure credential storage.

The practical exercises demonstrated important cloud-security risks including excessive or exposed permissions, publicly accessible S3 resources, hardcoded AWS credentials, and insufficient protection of sensitive cloud data.

2. Scope

The assessment was limited to the authorized Pwned Labs training environments provided for the practical exercises.

The assessment covered:

- AWS IAM
- Amazon S3
- IAM policy enumeration
- S3 bucket enumeration
- S3 object access
- Cloud credential exposure
- Least-privilege security
- Secure cloud storage

No unrelated cloud resources were targeted.

3. Methodology

The practical assessment followed a hands-on enumeration and verification approach.

The main activities were:

1. Identify the AWS IAM identity.
2. Enumerate IAM policies and permissions.
3. Analyze S3-related permissions.
4. Enumerate accessible S3 buckets and objects.
5. Identify security weaknesses.
6. Verify the impact of the identified permissions.
7. Retrieve the lab flags where permitted by the challenge.
8. Document the evidence using screenshots.
9. Identify appropriate security controls and recommendations.

The assessment used the **AWS CLI** within the authorized Pwned Labs environments.

4. Lab 1 — Intro to AWS IAM Enumeration

4.1 Lab Information

Lab Name: Intro to AWS IAM Enumeration

Platform: Pwned Labs

URL: <https://pwnedlabs.io/explore>

Cloud Services: AWS IAM and Amazon S3

4.2 Objective

The objective of this lab was to enumerate AWS IAM permissions and understand how an IAM user's permissions can provide access to specific cloud resources. I identified the IAM user, reviewed its policies, examined the S3 permissions, and used the permitted access to retrieve the lab flag. Pasted text

4.3 AWS Identity Enumeration

I first used the AWS Security Token Service (STS) command to verify the identity of the AWS user being used in the lab. The output displayed the User ID, AWS Account ID, and ARN, confirming the IAM user as dev01.

```
Default output format [None]: json
PS C:\WINDOWS\system32> aws sts get-caller-identity
{
  "UserId": "AIDA3SFMDAPOWFB7BSGME",
  "Account": "794929857501",
  "Arn": "arn:aws:iam::794929857501:user/dev01"
}
```

Figure 1: AWS STS identity verification for the lab IAM user.

4.4 IAM Policy Enumeration

Next, I enumerated the policies attached to the dev01 IAM user. The output showed policies associated with the user, including AmazonGuardDutyReadOnlyAccess and the custom dev01 policy.

```
PS C:\WINDOWS\system32> aws iam list-attached-user-policies --user-name dev01
{
  "AttachedPolicies": [
    {
      "PolicyName": "AmazonGuardDutyReadOnlyAccess",
      "PolicyArn": "arn:aws:iam::aws:policy/AmazonGuardDutyReadOnlyAccess"
    },
    {
      "PolicyName": "dev01",
      "PolicyArn": "arn:aws:iam::794929857501:policy/dev01"
    }
  ]
}
```

Figure 2: Attached IAM policies for the dev01 user.

4.5 S3 Access Policy Analysis

I then examined the inline S3_Access policy assigned to the dev01 user. The policy allowed s3:ListBucket and s3:GetObject actions on the hl-dev-artifacts bucket and its objects.

```
PS C:\WINDOWS\system32> aws iam get-user-policy --user-name dev01 --policy-name S3_Access
{
  "UserName": "dev01",
  "PolicyName": "S3_Access",
  "PolicyDocument": {
    "Version": "2012-10-17",
    "Statement": [
      {
        "Effect": "Allow",
        "Action": [
          "s3:ListBucket",
          "s3:GetObject"
        ],
        "Resource": [
          "arn:aws:s3:::hl-dev-artifacts",
          "arn:aws:s3:::hl-dev-artifacts/*"
        ]
      }
    ]
  }
}
```

Figure 3: S3 permissions defined in the S3_Access IAM policy.

4.6 S3 Bucket Enumeration

Using the permissions identified in the policy, I enumerated the hl-dev-artifacts S3 bucket. The command successfully returned the objects available in the bucket, including flag.txt.

```
PS C:\WINDOWS\system32> aws s3 ls s3://hl-dev-artifacts
2023-10-02 01:39:53      1235 android-kotlin-extensions-tooling-232.9921.47.pom
2023-10-02 01:39:53    214036 android-project-system-gradle-models-232.9921.47-sources.jar
2023-10-02 01:38:05         32 flag.txt
```

Figure 4: Enumeration of the permitted S3 bucket showing flag.txt.

4.7 Flag Retrieval

After identifying the accessible flag.txt object, I used the s3:GetObject permission to retrieve it from the bucket. The flag was successfully displayed in the terminal.

```
PS C:\WINDOWS\system32> aws s3 cp s3://hl-dev-artifacts/flag.txt -
d8ae4495888545df0c904551935c7514
```

Figure 5: Successful retrieval of the lab flag from the S3 bucket.

4.8 Lab Completion

After retrieving the flag, I submitted it on Pwned Labs. The platform displayed the successful completion status with a green check mark.

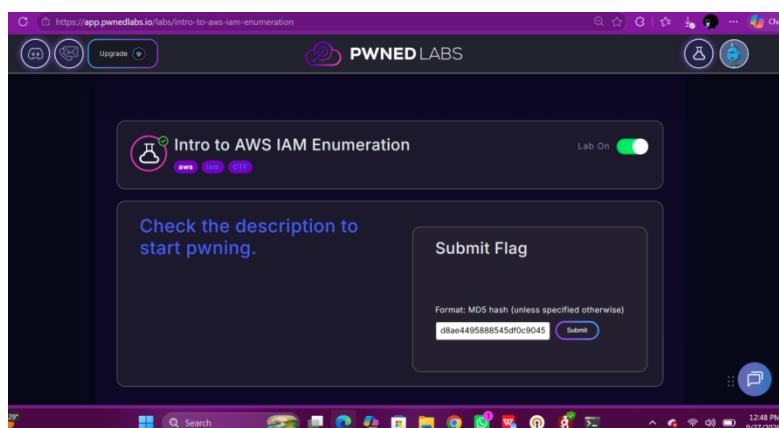


Figure 6: Successful completion of the Intro to AWS IAM Enumeration lab.

4.9 Finding — IAM and S3 Access

Finding ID: CS-01

Title: IAM User with S3 Resource Access

Cloud Service: AWS IAM / Amazon S3

Severity: Medium

Description

The dev01 IAM user had an inline policy named S3_Access that allowed s3:ListBucket and s3:GetObject permissions for the specified S3 resources.

Why is it Risky?

If the IAM credentials were compromised, an unauthorized person could use the granted permissions to enumerate and retrieve objects from the permitted S3 bucket.

Potential Impact

Unauthorized access to objects stored in the permitted S3 bucket could result in exposure of sensitive information.

Recommendation

The organization should apply the principle of least privilege and grant only the permissions required for the user's role. IAM policies should be reviewed regularly and unused permissions should be removed.

5. Lab 2 — AWS S3 Enumeration Basics

5.1 Lab Information

Lab Name: AWS S3 Enumeration Basics

Platform: Pwned Labs

Cloud Service: Amazon S3

5.2 Objective

The objective of this lab was to enumerate an AWS S3 bucket, identify publicly accessible objects and folders, and investigate how misconfigured access controls could expose sensitive cloud resources and credentials.

5.3 Public S3 Bucket Enumeration

I first enumerated the public S3 bucket using anonymous access. The bucket listing revealed several directories, including admin/, migration-files/, shared/, and static/, along with the index.html object.

```
PS C:\WINDOWS\system32> aws s3 ls s3://dev.huge-logistics.com/ --no-sign-request
PRE admin/
PRE migration-files/
PRE shared/
PRE static/
2023-10-16 22:00:47 5347 index.html
```

Figure 7: Public S3 bucket enumeration showing available folders and objects.

5.4 Sensitive Migration File Discovery

The publicly accessible shared/ directory contained a file named hl_migration_project.zip. I downloaded the archive and extracted its contents. The archive contained a PowerShell migration script.

```
PS C:\WINDOWS\system32> aws s3 ls s3://dev.huge-logistics.com/shared/ --no-sign-request
2023-10-16 20:08:33      0
2026-06-20 03:23:43    1877 hl_migration_project.zip
```

Figure 8: Publicly accessible migration ZIP file identified in the shared S3 directory.

5.5 Hardcoded Credentials

After extracting the migration archive, I identified a PowerShell migration script containing hardcoded AWS credentials.

This represented a significant security exposure because credentials stored directly inside scripts can potentially be obtained and reused by an unauthorized person.

```
PS C:\WINDOWS\system32> Get-Content "$env:USERPROFILE\Downloads\hl_migration_project\migrate_secrets.ps1"
# AWS Configuration
$accessKey = 
$secretKey = 
$region = "us-east-1"
```

Figure 9: Migration script containing exposed AWS credentials.

Note: Secret credential values should be redacted or cropped in the final report.

5.6 AWS Identity Verification

I loaded the discovered lab credentials into temporary AWS environment variables and verified the authenticated identity using AWS STS. The authenticated IAM identity was it-admin.

```
PS C:\WINDOWS\system32> aws sts get-caller-identity
{
  "UserId": "AIDA3SFMDAPOYPM3X2TB7",
  "Account": "794929857501",
  "Arn": "arn:aws:iam::794929857501:user/pam-test"
}
```

Figure 10: AWS STS identity verification showing the authenticated IAM user.

5.7 Admin Directory Enumeration

Using the authenticated identity, I enumerated the admin/ directory of the S3 bucket. The directory contained flag.txt and other files.

```
PS C:\WINDOWS\system32> aws s3 ls s3://dev.huge-logistics.com/admin/
2023-10-16 20:08:38      0
2024-12-02 19:57:44     32 flag.txt
2023-10-17 01:24:07    2425 website_transactions_export.csv
```

Figure 11: Authenticated access to the S3 admin directory showing flag.txt.

5.8 Flag Submission

The identified flag was retrieved and submitted through the Pwned Labs interface. The challenge showed successful completion.

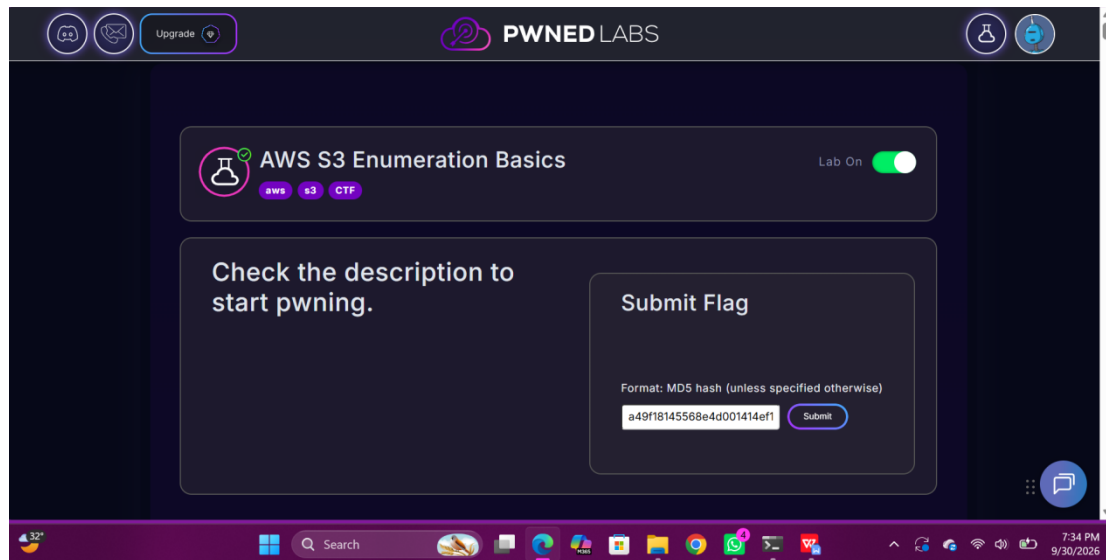


Figure 12: Successful completion of the AWS S3 Enumeration Basics lab.

6. Finding — Public S3 Exposure and Hardcoded Credentials

Finding ID: CS-02

Title: Public S3 Exposure Leading to Credential Disclosure

Cloud Service: Amazon S3

Severity: High

Description

The S3 environment exposed publicly accessible resources. The shared/ directory contained a migration ZIP archive that could be downloaded without authentication. The extracted migration script contained AWS credentials.

Why is it Risky?

Publicly accessible cloud storage containing credentials creates a serious security risk. An unauthorized person could obtain the credentials and attempt to authenticate to AWS using the associated IAM identity.

What Caused the Weakness?

The weakness resulted from two related security issues:

1. Sensitive S3 resources were exposed through inappropriate access controls.
2. AWS credentials were stored directly inside a migration script.

Potential Impact

An attacker who obtained the exposed credentials could authenticate as the associated IAM identity and access resources allowed by that identity. In the lab, the credentials enabled authenticated access to the S3 admin/ directory.

Recommendation

The organization should:

- Keep sensitive S3 buckets and objects private by default.
- Apply least-privilege IAM permissions.
- Never hardcode AWS access keys or secret keys in scripts.
- Use a dedicated secrets-management solution.
- Rotate credentials immediately if exposure occurs.
- Regularly review S3 bucket policies and IAM permissions.
- Enable appropriate cloud logging and monitoring.

7. Findings Summary

Finding ID	Finding	Cloud Service	Severity
CS-01	IAM user with S3 resource access	AWS IAM / S3	Medium
CS-02	Public S3 exposure and hardcoded credentials	Amazon S3	High

These findings demonstrate two different areas of cloud security: **identity and access management** and **secure cloud storage**.

8. Shared Responsibility Model

The Shared Responsibility Model divides security responsibilities between the cloud provider and the cloud customer.

The cloud provider is responsible for security **of** the underlying cloud infrastructure, while the customer remains responsible for security **in** the cloud, depending on the service being used.

In these labs, configuring IAM permissions, protecting credentials, and controlling S3 access were customer-side security responsibilities.

9. Importance of IAM Least Privilege

The principle of least privilege means that a user or service should receive only the permissions necessary to perform its required tasks.

In Lab 1, the dev01 user had permissions for specific S3 actions. Reviewing and restricting these permissions helps reduce the impact if the credentials are compromised.

Least privilege should be implemented by limiting:

- Required actions
- Required resources
- Required users or roles
- Duration of access where appropriate

10. IAM Access vs Public S3 Access

IAM-controlled access requires an identity to authenticate and have appropriate permissions.

Public S3 access can allow resources to be accessed without normal authentication, depending on the bucket or object configuration.

The second lab demonstrated why public access to sensitive cloud storage can be dangerous, particularly when files contain credentials or other sensitive information.

11. IAM Policy Components

An IAM policy generally defines important components such as:

- **Effect** — specifies whether an action is allowed or denied.
- **Action** — specifies the AWS operation that can be performed.
- **Resource** — specifies the AWS resource to which the permission applies.
- **Principal** — identifies the identity to which a resource-based policy applies.
- **Condition** — specifies additional conditions under which the permission applies.

In Lab 1, the `S3_Access` policy included an **Allow** effect with S3 actions such as `s3:ListBucket` and `s3:GetObject`.

12. Security Control for Sensitive Storage

One important security control for sensitive cloud storage is to **keep the storage private and apply least-privilege access controls**.

Additional controls include:

- Encryption at rest and in transit
- Strong IAM policies
- Secure secrets management
- Logging and monitoring
- Regular access reviews
- Credential rotation
- Blocking unnecessary public access

13. Recommendations

Based on the practical assessment, the following controls are recommended:

13.1 Apply Least Privilege

IAM users and roles should only receive the permissions required for their tasks.

13.2 Keep Sensitive S3 Resources Private

Sensitive buckets and objects should not be publicly accessible unless there is a documented business requirement.

13.3 Do Not Hardcode Credentials

AWS access keys and secret keys should never be stored directly inside scripts or configuration files.

13.4 Use Secrets Management

Sensitive credentials should be stored using an appropriate secrets-management service rather than plain-text files.

13.5 Rotate Exposed Credentials

If credentials are accidentally exposed, they should be revoked or rotated immediately.

13.6 Review IAM and S3 Permissions

IAM policies and S3 bucket policies should be reviewed regularly to identify unnecessary permissions and unintended public access.

13.7 Enable Monitoring

Appropriate AWS logging and monitoring should be used to detect unusual access to IAM and S3 resources.

14. Evidence Summary

The practical evidence collected during the two labs includes:

Lab 1 — Intro to AWS IAM Enumeration

Screenshot 1: AWS STS identity verification

Screenshot 2: Attached IAM policies

Screenshot 3: S3_Access policy

Screenshot 4: S3 bucket enumeration

Screenshot 5: Flag retrieval

Screenshot 6: Pwned Labs completion

Lab 2 — AWS S3 Enumeration Basics

Screenshot 7: Public S3 bucket enumeration

Screenshot 8: Public migration ZIP

Screenshot 9: Hardcoded credentials — **redact secrets**

Screenshot 10: it-admin identity verification

Screenshot 11: admin/ directory and flag

Screenshot 12: Pwned Labs completion

15. Conclusion

The Cloud Security practical assessment provided hands-on experience with AWS IAM and Amazon S3 security.

The first lab demonstrated how IAM enumeration can reveal the permissions assigned to an AWS user and how those permissions can provide access to specific S3 resources. The second lab demonstrated how improperly secured S3 resources can expose sensitive files and credentials.

Overall, the practical work highlighted the importance of **least privilege, private cloud storage, secure credential management, regular permission reviews, and cloud monitoring.**